Contents

AWS IAM and security configuration review **1**
Executive summary . . . 1
Findings, ranked by risk . . . 2
F-01 Critical: the CI role is administrator and trusts every repository in the organization . . . 2
F-02 Critical: the root user has an active access key, no MFA, and signs in for routine work . . . 3
F-03 Critical: customer exports are readable by anyone on the internet . . . 3
F-04 High: human administrators work without MFA . . . 3
F-05 High: the PlatformOps group can make itself administrator . . . 4
F-06 High: workloads use long-lived access keys with broad permissions . . . 4
F-07 High: CloudTrail covers one region and its logs can be altered undetected . . . 5
F-08 Medium: an undocumented account has full control of the customer exports bucket . . . 5
F-09 Low: buckets accept plain HTTP and lack the storage baseline . . . 6
Quick wins and planned work . . . 6
Service control policy recommendation . . . 7
Verification . . . 8
Out of scope . . . 8
Check reference . . . 8

SOC 2 control to evidence map **9**
How to read this . . . 9
Map . . . 9
Evidence index . . . 11

AWS IAM and security configuration review

> **This sample covers a FICTIONAL client, Harbor Goods, a mid-size retailer with account `<account-id>`.** The client, its staff and its account are fictional. Each repository in this portfolio is a separate engagement with Harbor Goods, a fictional mid-size retailer. The repository files reproduce all findings below through `make verify`.

Item	Value
Account	`<account-id>` (fictional), home region `us-east-1`
Method	Offline review of read-only exports plus the account's Terraform; no write access was used
Inputs	`data/synthetic/before/export/`, `data/synthetic/before/terraform/`
Tools	`scripts/iam_review.py` (17 checks), Checkov 3.3.19 (Terraform)
Method detail	`docs/methodology.md`
Evidence	`evidence/` holds the unedited output of both tools
Prepared by	Independent AWS consultant

Executive summary

Two independent routes currently allow account takeover, and a third exposes customer data to anyone. Each also leaves gaps that would complicate an investigation.

1. **Every repository in the GitHub organization has a path to administrator access.** The CI role combines trust in `repo:harborgoods/*` with `Action: *` on `Resource: *`. Any repository's workflow can assume the role, whether the repository is newly created or forgotten.
2. **Daily administration uses root with an active access key and no MFA.** IAM cannot restrict root. Exposure of either its password or its key therefore compromises the entire account.

3. **The customer exports are publicly readable.** Anyone with internet access has permission under the bucket policy to read every object.

Four other conditions increase this risk. Human administrators lack MFA, and the operations group can make itself administrator using `iam:*` and `iam:PassRole` on `*`. Three long-lived access keys are as old as 716 days. CloudTrail records a single region and does not validate log files.

Most fixes take little time and require small changes. Of the twelve recommendations, nine can be completed during the first week without application code changes. The scoped replacements are in `remediation/`. With those replacements applied, the original checks return **0 findings**, and Checkov returns **0 failed checks** (evidence, evidence).

Severity	Raw check hits	Report findings
Critical	5	3 (F-01 to F-03)
High	15	4 (F-04 to F-07)
Medium	5	1 (F-08)
Low	2	1 (F-09)

Each line in `iam-review-before.txt` is a raw hit. A finding combines hits with the same underlying cause and remedy. Priority reflects likelihood multiplied by impact; hit totals do not determine rank.

Findings, ranked by risk

F-01 Critical: the CI role is administrator and trusts every repository in the organization

Checks: IAM-001, IAM-009. **Checkov:** CKV_AWS_62, CKV_AWS_63, CKV_AWS_286 to CKV_AWS_290, CKV_AWS_355, CKV2_AWS_40.

Evidence (iam-review-before.txt):

```
CRITICAL IAM-001  role/ci-deploy via ci-deploy-inline: Action * on Resource *
HIGH     IAM-009  role/ci-deploy: sub wildcard: repo:harborgoods/*
```

Source resources: `aws_iam_role.ci_deploy` and `aws_iam_role_policy.ci_deploy` in `data/synthetic/before/terraform/i`

Impact. Every workflow run receives a GitHub-signed OIDC token. The role's `StringLike` match for `repo:harborgoods/*` accepts workflows across the organization's repositories, from any branch or member pull request. Once assumed, the role permits unrestricted actions, including user creation, access to every bucket and CloudTrail shutdown. Its inline policy Sid, `TemporaryFullAccessForPipeline`, indicates that this access was probably intended to be temporary.

Recommended fix. Use `StringEquals` to restrict trust to one repository and one GitHub environment. Require reviewers for that environment. Limit pipeline permissions to its actual tasks: uploading release artifacts within one prefix and updating one Lambda function.

Scoped rewrite (`ci-deploy-trust.json`, `ci-deploy-permissions.json`):

```
"Condition": {
  "StringEquals": {
    "token.actions.githubusercontent.com:aud": "sts.amazonaws.com",
    "token.actions.githubusercontent.com:sub": "repo:harborgoods/reporting-app:environment:production"
  }
}
```

```
{"Sid": "UploadReleaseArtifacts", "Effect": "Allow", "Action": ["s3:GetObject", "s3:PutObject"],
 "Resource": "arn:aws:s3:::harborgoods-release-artifacts/reporting-app/*"},
{"Sid": "DeployOneFunction", "Effect": "Allow",
 "Action": ["lambda:GetFunction", "lambda:UpdateFunctionCode", "lambda:PublishVersion"],
 "Resource": "arn:aws:lambda:us-east-1:<account-id>:function:reporting-app"}
```

Validate the pipeline's required actions before the switch, using either 90 days of the role's CloudTrail events or IAM Access Analyzer policy generation. Omitted permissions cause visible CI failures, which makes this restriction the safer approach.

F-02 Critical: the root user has an active access key, no MFA, and signs in for routine work

Checks: ROOT-001, ROOT-002, ROOT-003.

Evidence:

```
CRITICAL ROOT-001 root: access key 1 is active
CRITICAL ROOT-002 root: mfa_active is false
HIGH     ROOT-003 root: password used 5 days before snapshot
```

Source row: `<root_account>` in `credential-report.csv`. The most recent key use accessed S3 ten days before the snapshot.

Impact. Neither IAM policies nor permission boundaries constrain root. Consequently, none of this report's other controls restricts its access. Someone with a leaked root key or phished password gains complete, persistent control over the account and billing.

Recommended fix. Identify the process using the root key and migrate it to a role; the last recorded use was S3 in `us-east-1`. Disable the key and monitor for failures over one week before deleting it. Enroll two hardware MFA devices for root and keep its password in the company vault. Configure an alarm for every root sign-in through a CloudWatch metric filter on the trail log group established in F-07. Use IAM Identity Center for routine administration.

Scoped rewrite. Root permissions cannot be narrowed, so no rewrite applies. Remove its keys, enable MFA, leave root unused and monitor it with alarms.

F-03 Critical: customer exports are readable by anyone on the internet

Checks: S3-001. **Checkov:** CKV_AWS_70, CKV_AWS_53 to CKV_AWS_56, CKV2_AWS_6.

Evidence:

```
CRITICAL S3-001   s3://harborgoods-customer-exports: Principal * allowed s3:GetObject
```

Source statement: `PublicReadForPartnerDownloads` in `bucket-policies/harborgoods-customer-exports.json`. `s3.tf` also disables the bucket's public access block.

Impact. Knowing or guessing an object key is enough to download customer data without authentication. Logs, email and browser history commonly expose these keys. Most contracts require reporting this data exposure.

Recommended fix. Enable each of the four public access block settings and delete the anonymous-access statement. Authorize the partner through a role restricted to its prefix, as described in F-08. Provide short-lived presigned URLs if partners require links. Determine whether an incident occurred by checking S3 server access logs for anonymous `GetObject` requests, or CloudTrail data events where enabled.

Scoped rewrite: F-08 supplies replacements for both statements in this bucket policy.

F-04 High: human administrators work without MFA

Checks: IAM-001, IAM-005, IAM-008. **Checkov:** CKV_AWS_274.

Evidence:

```
CRITICAL IAM-001  group/Admins via AdministratorAccess: Action * on Resource *
HIGH     IAM-005  group/Admins via AdministratorAccess: 17/17 sensitive actions (cloudtrail:DeleteTrail,
HIGH     IAM-008  user/alice.admin: console password, no MFA device
```

Impact. Phishing the password of `alice.admin` alone provides unrestricted administrator access. That access allows an attacker to disable CloudTrail and erase evidence of the activity.

Recommended fix. Require MFA and a short session for human access through IAM Identity Center, then remove the `Admins` group. During the transition, apply the deny-without-MFA guardrail below to all human groups. The same policy lets each user enroll an MFA device on their own user only, and it permits nothing else until the user authenticates with MFA.

Scoped rewrite (`require-mfa-guardrail.json`):

```
{
  "Sid": "DenyEverythingExceptMfaSetupWithoutMfa",
  "Effect": "Deny",
  "NotAction": ["iam:ChangePassword", "iam:CreateVirtualMFADevice", "iam:EnableMFADevice", "iam:GetUser",
                "iam:ListMFADevices", "iam:ListVirtualMFADevices", "iam:ResyncMFADevice", "sts:GetSession
  "Resource": "*",
  "Condition": {"BoolIfExists": {"aws:MultiFactorAuthPresent": "false"}}
}
```

F-05 High: the PlatformOps group can make itself administrator

Checks: IAM-002, IAM-003, IAM-004, IAM-005. **Checkov:** CKV2_AWS_40, CKV_AWS_286, CKV_AWS_287, CKV_AWS_289, CKV_AWS_290, CKV_AWS_355.

Evidence:

```
HIGH     IAM-002  group/PlatformOps via platform-ops: iam:* on *
HIGH     IAM-004  group/PlatformOps via platform-ops: iam:* lets it pass any role
HIGH     IAM-004  group/PlatformOps via platform-ops: iam:PassRole lets it pass any role
HIGH     IAM-005  group/PlatformOps via platform-ops: 10/17 sensitive actions (iam:AttachRolePolicy, ...)
MEDIUM   IAM-003  group/PlatformOps via platform-ops: ec2:StopInstances, ec2:TerminateInstances on *
```

Impact. Members can use `iam:*` to attach `AdministratorAccess` to themselves, which makes this group effectively administrative. With `iam:PassRole` on `*`, they can launch an instance under any account role, including the CI role, and exercise its permissions. Terminate access on `*` extends to all instances, including those outside the platform team.

Recommended fix. Retain read access to IAM. Restrict `PassRole` to `app-*` roles passed to EC2, and require MFA. Allow stop and terminate only for instances with the tag `team = platform`. Attach the F-04 guardrail as well; it lets members manage only their own MFA device, so it does not lock out a new engineer. Require reviewed Terraform changes for role and policy updates rather than console edits.

Scoped rewrite (`platform-ops.json`):

```
{"Sid": "PassOnlyAppRolesToEc2WithMfa", "Effect": "Allow", "Action": "iam:PassRole",
 "Resource": "arn:aws:iam::<account-id>:role/app-*",
 "Condition": {"StringEquals": {"iam:PassedToService": "ec2.amazonaws.com"},
               "Bool": {"aws:MultiFactorAuthPresent": "true"}}},
{"Sid": "StopAndTerminatePlatformInstancesOnly", "Effect": "Allow",
 "Action": ["ec2:StopInstances", "ec2:TerminateInstances"],
 "Resource": "arn:aws:ec2:*:<account-id>:instance/*",
 "Condition": {"StringEquals": {"aws:ResourceTag/team": "platform"}}}
```

This tag condition depends on restricting who can change the tag. Add an SCP or tag policy that reserves setting `team` to the provisioning pipeline; this remains part of the planned work below.

F-06 High: workloads use long-lived access keys with broad permissions

Checks: IAM-002, IAM-005, IAM-006, IAM-007. **Checkov:** CKV_AWS_273, CKV_AWS_40, CKV_AWS_288 to CKV_AWS_290, CKV_AWS_355.

Evidence:

```
HIGH     IAM-002  user/deploy-bot via deploy-bot-s3: s3:* on *
HIGH     IAM-002  user/legacy-reporting via AmazonAthenaFullAccess: athena:* on *
```

```
HIGH     IAM-005  user/deploy-bot via deploy-bot-s3: 2/17 sensitive actions (s3:DeleteBucket, ...)
HIGH     IAM-006  user/deploy-bot: key 1 is 406 days old
HIGH     IAM-006  user/legacy-reporting: key 1 is 716 days old
HIGH     IAM-006  user/legacy-reporting: key 2 is 302 days old
MEDIUM   IAM-007  user/legacy-reporting: key 1 unused 211 days
MEDIUM   IAM-007  user/legacy-reporting: key 2 never used
```

Impact. The 406-day-old `deploy-bot` key permits reading, overwriting and deleting data in any bucket. It also permits rewriting bucket policies, including the trail bucket's policy. Both CI secrets and Terraform state contain the key (`aws_iam_access_key.deploy_bot`). Two keys remain active for `legacy-reporting`: one has never been used, and the other has been idle for seven months. That credential receives no oversight.

Recommended fix. Switch `deploy-bot` to the F-01 OIDC role and remove the user. Disable both `legacy-reporting` keys immediately. Delete that user after two weeks if no failures occur. For any report that still requires Athena, assign a role restricted to its workgroup. Configure the AWS Config rule `access-keys-rotated` with 90 days to detect new keys that age without attention.

Scoped rewrite. Workloads retain no IAM users after remediation; F-01 provides the CI role.

F-07 High: CloudTrail covers one region and its logs can be altered undetected

Checks: CT-001, CT-002, S3-003 (trail bucket). **Checkov:** CKV_AWS_67, CKV_AWS_36, CKV_AWS_35, CKV2_AWS_10, CKV_AWS_252.

Evidence:

```
HIGH     CT-001   cloudtrail: trails: management-events
MEDIUM   CT-002   trail/management-events: LogFileValidationEnabled false
LOW      S3-003   s3://harborgoods-trail-logs: no Deny on aws:SecureTransport false
```

Source files: `describe-trails.json` and `cloudtrail.tf`.

Impact. The trail leaves all activity outside `us-east-1` unrecorded. An attacker using the credentials described above would choose those regions to mine cryptocurrency or stage data. The absence of log file validation prevents proof that logs remain unedited. Because the trail does not deliver to CloudWatch Logs, it provides no destination for alarms on root sign-in or `StopLogging`.

Recommended fix. Enable multi-region coverage and log file validation. Use a customer managed KMS key for encryption and send the trail to a CloudWatch Logs group that retains records for at least one year. Send delivery notifications to an encrypted SNS topic with a policy limited to this trail. Apply the secure bucket baseline to the destination bucket. Implementation is in `remediation/terraform/cloudtrail.tf` and `kms.tf`.

F-08 Medium: an undocumented account has full control of the customer exports bucket

Checks: S3-002.

Evidence:

```
MEDIUM   S3-002   s3://harborgoods-customer-exports: account <partner-account-id> allowed s3:*
```

Impact. The Sid identifies account `<partner-account-id>` as the analytics vendor. Its permissions cover reading, overwriting and deleting all exports, plus changing bucket configuration. A grant to that account's root lets the vendor's IAM administrators decide which identities within the account receive access.

Recommended fix. Document the vendor as an approved third party in the review scope. Authorize a single named role to list and read only its prefix. Give the bucket a separate KMS key, with a policy that permits the role to decrypt solely through S3 (`kms:ViaService`). This keeps the vendor from using the audit-log encryption key. The client verified the vendor relationship; the remediated scope therefore marks `<partner-account-id>` as trusted.

Scoped rewrite (`customer-exports-bucket-policy.json`):

```
{"Sid": "DenyInsecureTransport", "Effect": "Deny", "Principal": "*", "Action": "s3:*",
 "Resource": ["arn:aws:s3:::harborgoods-customer-exports", "arn:aws:s3:::harborgoods-customer-exports/*"]
 "Condition": {"Bool": {"aws:SecureTransport": "false"}}},
{"Sid": "PartnerListsItsPrefix", "Effect": "Allow",
 "Principal": {"AWS": "arn:aws:iam::<partner-account-id>:role/partner-ingest"}, "Action": "s3:ListBucket"
 "Resource": "arn:aws:s3:::harborgoods-customer-exports",
 "Condition": {"StringLike": {"s3:prefix": ["partner-a/*"]}}},
{"Sid": "PartnerReadsItsPrefix", "Effect": "Allow",
 "Principal": {"AWS": "arn:aws:iam::<partner-account-id>:role/partner-ingest"}, "Action": "s3:GetObject",
 "Resource": "arn:aws:s3:::harborgoods-customer-exports/partner-a/*"}
```

F-09 Low: buckets accept plain HTTP and lack the storage baseline

Checks: S3-003. **Checkov:** CKV_AWS_18, CKV_AWS_21, CKV_AWS_144, CKV_AWS_145, CKV2_AWS_61, CKV2_AWS_62.

Evidence:

```
LOW      S3-003   s3://harborgoods-customer-exports: no Deny on aws:SecureTransport false
```

Both buckets also fail checks for versioning, KMS encryption, access logging, lifecycle and event notifications in `checkov-before.txt`.

Impact. The standalone impact is low because SDKs default to TLS. However, without versioning and access logs, an overwrite or deletion through F-01, F-06 or F-08 leaves no way to restore or trace the affected data.

Recommended fix. Apply the shared baseline through the small `secure-bucket` module at `remediation/terraform/modules` Place the TLS-only deny from F-08 at the beginning of every bucket policy.

Quick wins and planned work

#	Change	Fixes	Effort	When
1	Turn on S3 public access block for the account and the exports bucket	F-03	Minutes	Day 1
2	Deactivate the root access key; enable MFA on root	F-02	1 hour	Day 1
3	Pin the CI role trust to one repo and environment	F-01	1 hour	Day 1
4	Deactivate both `legacy-reporting` keys	F-06	Minutes	Day 1
5	Attach the MFA guardrail to `Admins` and `PlatformOps`; enrol MFA	F-04, F-05	2 hours	Week 1
6	Make the trail multi-region with log file validation	F-07	1 hour	Week 1
7	Replace the partner's account-root grant with a prefix-scoped role grant	F-08	2 hours	Week 1

#	Change	Fixes	Effort	When
8	Scope the CI role permissions from CloudTrail usage	F-01	1 day	Week 1
9	Rewrite `platform-ops` as in F-05	F-05	1 day	Week 1
10	Move humans to IAM Identity Center; delete IAM users and the `Admins` group	F-04, F-06	1 to 2 weeks	Planned
11	KMS key, CloudWatch Logs delivery, root sign-in and `StopLogging` alarms	F-02, F-07	2 days	Planned
12	Secure bucket module on every bucket; decide on cross-region replication	F-09	2 days	Planned

Schedule additional work beyond these findings: establish AWS Organizations with service control policies, define a `team` tag policy, and enable AWS Config rules and Security Hub foundational controls to run these checks continuously.

Service control policy recommendation

When Harbor Goods brings this account into AWS Organizations, use `remediation/scps/baseline-guardrails.json` as an initial SCP. Its statements only deny access, so retain the default `FullAWSAccess` policy alongside it:

Statement	Backs up	Why
`DenyLeavingTheOrganization`	All	A compromised administrator cannot take the account out from under the guardrails
`DenyRootUserActions`	F-02	Root cannot act in member accounts, even with a leaked key
`ProtectCloudTrail`	F-07	Nobody except the break-glass role can stop, delete or narrow the trail
`ProtectS3PublicAccessBlock`	F-03	The account-level public access block stays on
`OnlyThePipelineSetsTheTeamTag`	F-05	The `team = platform` condition on terminate cannot be bypassed by retagging
`ProtectExemptRoles`	All	Nobody can create or change the two exempt roles to claim their exemption

Deployment has two caveats. SCPs do not affect the management account; its root user still requires MFA and alarms. A root deny in member accounts also prevents root-only operations, including removal of a bucket policy that denies everyone. For those operations, the runbook calls for detaching the SCP from the affected

account, completing the task and reattaching it. Service-managed StackSets deploys the two exempt roles from the management account and is the sole principal authorized to modify them.

Verification

`remediation/` and `data/synthetic/after/` contain the corrected state. Running the tools without modifications produces these results:

- `scripts/iam_review.py data/synthetic/after/export` returns **no findings** (evidence).
- Checkov returns **0 failed, 5 skipped** for `remediation/terraform` (evidence). Resource-level notes explain every skip: S3 cannot deliver access logs to an SSE-KMS bucket, the access log bucket cannot record its own access, and cross-region replication remains item 12 above.
- `pytest` verifies that `remediation/policies/` matches the policies in both the remediated export and Terraform. It also proves that the SCP contains only denies, meets the 5,120-character limit, and that `evidence/` contains every tool-output line quoted here.
- `make evidence-check` rebuilds all evidence files and fails whenever a committed version differs.
- The optional manual command `make test-live` submits the rewrites to IAM Access Analyzer and the IAM policy simulator for confirmation in a non-production account; the methodology describes this process.

Out of scope

- Direct account access was outside scope. Only exports were reviewed, so findings describe the snapshot rather than the account's present condition.
- Workload and network protections were excluded: security groups, VPC architecture, EC2 and container hardening, and application code.
- AWS Organizations and IAM Identity Center settings were recommended but not assessed. The proposed SCP does not constitute a review of policies already in place.
- GuardDuty, Security Hub, Macie and Inspector detective services were outside the review.
- KMS key policies were excluded except for the audit key added during remediation.
- AWS-managed policy content was outside scope; the export includes only statements relevant to this review.
- No penetration testing or exploitation of findings was performed.
- No SOC 2 compliance opinion is provided. The control to evidence map connects controls with supporting evidence. Issuing a SOC 2 report requires a licensed CPA firm.

Check reference

ID	Severity	What it flags
ROOT-001	Critical	Root user has an active access key
ROOT-002	Critical	Root user has no MFA device
ROOT-003	High	Root password used within the rotation window (90 days)
IAM-001	Critical	`Allow` of `*` on `*`
IAM-002	High	Wildcard actions beyond read-only prefixes, or `Allow` with `NotAction`
IAM-003	Medium	Specific write actions on `Resource: *`
IAM-004	High	`iam:PassRole` (directly or through a wildcard) on `Resource: *`
IAM-005	High	Sensitive actions for users and groups without `Bool` MFA, `MultiFactorAuthAge`, or a `BoolIfExists` deny guardrail
IAM-006	High	Active access key older than 90 days
IAM-007	Medium	Active access key never used or unused for 90 days

ID	Severity	What it flags
IAM-008	High	User with a console password and no MFA
IAM-009	High	Role trust open to any AWS principal, federated trust with no `sub`, or a `sub` wildcard under `StringLike`
S3-001	Critical	Bucket policy allows `Principal: *` with no condition that limits the caller (org, account, VPC, source)
S3-002	Medium	Bucket policy grants an account that is not the owner or on the trusted list
S3-003	Low	Bucket policy has no deny for `aws:SecureTransport = false`
CT-001	High	No multi-region trail that is logging
CT-002	Medium	Trail without log file validation

This deliverable uses the fictional company Harbor Goods. Its account IDs come from AWS documentation examples. It represents no actual organization, individual or account.

SOC 2 control to evidence map

> **Sample for a FICTIONAL client, Harbor Goods (account `<account-id>`).** This is an evidence map, not an audit opinion. It shows which AWS configuration supports each SOC 2 criterion and where the proof lives, so the client's auditor can test it. Only a licensed CPA firm can issue a SOC 2 report or conclude that a control is designed or operating effectively.

How to read this

- **Criteria** are from the AICPA 2017 Trust Services Criteria (with the revised points of focus), Common Criteria
  (CC) series. Only the criteria that AWS identity, logging and storage configuration can support are listed. The summaries paraphrase the criteria; the auditor works from the AICPA text.
- **Evidence** points to files in this repository. For a real engagement they would be exported on the audit date and stored with a hash in the client's evidence locker.
- **Status** uses four values:
  - *Gap*: the configuration contradicts the criterion; the finding is linked.
  - *Supported*: the configuration and its evidence support the criterion at the snapshot.
  - *Partial*: some evidence exists, but a process or a period of operation is missing.
  - *Not covered*: outside this review; another source of evidence is needed.
- A configuration snapshot shows **design** at one point in time. A Type 2 report also needs evidence that the control **operated** through the period, such as AWS Config history, access review tickets and alarm records.

Map

Criterion	What it asks (summary)	AWS control or configuration	Evidence artifact	Before	After remediation
CC6.1	Logical access security over protected information assets	Root has MFA, no access keys, no routine use	`credential-report.csv` row `<root_account>`; checks ROOT-001 to ROOT-003	Gaps (F-02)	Supported
CC6.1	Same	MFA for every human principal; deny-without-MFA guardrail	`credential-report.csv` (`mfa_active`); `require-mfa-guardrail.json`; checks IAM-005, IAM-008	Gaps (F-04)	Supported
CC6.1	Same	Audit data and exports encrypted with separate customer managed KMS keys with rotation	`remediation/terraform/kms.tf`; `checkov-after.txt` (CKV_AWS_7, CKV_AWS_35, CKV_AWS_145 pass)	Gaps (F-07, F-09)	Supported
CC6.2	Register and authorize users before issuing credentials; remove credentials when no longer authorized	No unused or stale access keys; workload identities are roles, not users	`credential-report.csv` (key age and last use); checks IAM-006, IAM-007; Checkov CKV_AWS_273	Gaps (F-06)	Partial: needs the joiner and leaver process and IAM Identity Center records
CC6.3	Authorize, change and remove access by role, granting only the access each role needs, with segregation of duties	No `*:*` grants; no wildcard write grants; `PassRole` scoped to named roles and services	`account-authorization-details.json`; `remediation/policies/*.json`; checks IAM-001 to IAM-004; Checkov CKV_AWS_286 to CKV_AWS_290, CKV_AWS_355	Gaps (F-01, F-05)	Supported for design; Partial until a periodic access review is recorded
CC6.3	Same	CI deploys with a role scoped to one repository and one environment	`ci-deploy-trust.json`; `ci-deploy-permissions.json`; check IAM-009	Gaps (F-01)	Supported
CC6.6	Protect against threats from outside the system boundary	No anonymous bucket access; account-level S3 public access block	`bucket-policies/*.json`; `remediation/terraform/s3.tf` (`aws_s3_account_public_access_block`); check S3-001; Checkov CKV_AWS_53 to CKV_AWS_56, CKV_AWS_70, CKV2_AWS_6	Gaps (F-03)	Supported

Criterion	What it asks (summary)	AWS control or configuration	Evidence artifact	Before	After remediation
CC6.6	Same	Federated trust limited to an exact OIDC subject	`ci-deploy-trust.json`; check IAM-009	Gap (F-01)	Supported
CC6.7	Restrict transmission and removal of information to authorized users; protect it in transit	Bucket policies deny requests without TLS; third-party access limited to one prefix, read-only, with decrypt only through S3	`customer-exports-bucket-policy.json`, `trail-logs-bucket-policy.json`; checks S3-002, S3-003	Gap (F-08, F-09)	Supported
CC7.1	Detect configuration changes that introduce vulnerabilities	Automated checks run on every change to IAM or Terraform	`.github/workflows/ci.yml`, `make verify`; AWS Config rules (recommended)	Not covered	Partial: CI covers code; AWS Config would cover console drift
CC7.2	Monitor components for anomalies that indicate malicious acts, and analyze them	Multi-region CloudTrail with log file validation and CloudWatch Logs delivery	`describe-trails.json` (F-07), `remediation/terraform/cloudtrail.tf`; checks CT-001, CT-002; Checkov CKV_AWS_67, CKV_AWS_36, CKV2_AWS_10	Gap (F-07)	Partial: alarms for root sign-in and `StopLogging`, and their triage records, are planned work
CC8.1	Authorize, test, approve and implement changes to infrastructure	IAM and bucket policies changed through Terraform, pull request review and CI checks	`CODEOWNERS`; `.github/workflows/ci.yml`; `make verify`	Not covered	Partial: needs branch protection settings and merged PR history as operating evidence
CC9.2	Assess and manage risks from vendors and business partners	Each third-party account listed as approved; grants scoped to a role and a prefix	`review-scope.json` (`trusted_account_ids`); check S3-002	Gap (F-08)	Partial: needs the vendor due diligence record

Criteria not listed (for example CC1 to CC5 on governance and risk, CC6.4 and CC6.5 on physical assets, and the Availability, Confidentiality, Processing Integrity and Privacy categories) are outside a configuration review. Physical security of AWS data centers is AWS's responsibility; the auditor usually relies on AWS's own SOC 2 report for it as a carved-out subservice organization.

Evidence index

Artifact	What it proves	How it was produced
`data/synthetic/before/export/`	Account state at the snapshot	Read-only CLI exports (`get-account-authorization-details`, `get-credential-report`, `describe-trails`, `get-bucket-policy`)
`evidence/iam-review-before.txt`	27 check hits before remediation	`make evidence` (`scripts/iam_review.py`)
`evidence/iam-review-after.txt`	0 check hits after remediation	`make evidence`
`evidence/checkov-before.txt`	Checkov failures on the original Terraform	`make evidence` (Checkov 3.3.19)
`evidence/checkov-after.txt`	0 Checkov failures on the remediated Terraform	`make evidence`
`remediation/policies/`	The scoped policy documents	Written in this review; kept in step with Terraform by `pytest`
`remediation/scps/`	Organization guardrails that keep the fixes in place	Written in this review; checked by `pytest`